Lab 36 — Security Awareness: Run a Phishing Simulation with GoPhish

You will operate a phishing simulation platform end-to-end: campaign → landing page → tracked clicks → metrics. Use it **only** against accounts and domains you control.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free): - GoPhish (single Go binary) - `curl`, `unzip` - `docker.io` (for the MailHog SMTP sink in Step 4)

Step 1 — Install GoPhish

```
apt update && apt install -y unzip curl
```

```
cd /opt
```

```
curl -LO https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-64bit.zip
```

```
unzip -o gophish-v0.12.1-linux-64bit.zip -d gophish
```

```
cd gophish && chmod +x gophish
```

Step 2 — Bind the admin UI to the public IP (lab only)

```
sed -i 's/127.0.0.1:3333/0.0.0.0:3333/' config.json
```

```
./gophish 2>&1 | grep -E "admin|password" | head -3
```

Note the auto-generated admin password printed to stdout.

Open `https://<killercoda-host>:3333`, log in as `admin`, set a new password.

Step 3 — Configure the four GoPhish primitives

In the UI:

1. **Sending Profile** → SMTP host (use a local mailhog / mailcatcher for safe testing — see Step 4).
2. **Email Template** → "Password expiry — please reset" with a `{{.URL}}` token.
3. **Landing Page** → a "fake" reset form that captures clicks (do **not** capture passwords in real campaigns).
4. **Users & Groups** → upload a CSV of *opted-in* test users only.

Step 4 — Spin up a safe SMTP sink

```
apt install -y docker.io && systemctl start docker
```

```
docker run -d -p 1025:1025 -p 8025:8025 mailhog/mailhog
```

Configure GoPhish "Sending Profile" → host `127.0.0.1:1025`. Captured emails appear at `http://<host>:8025` instead of being delivered.

Step 5 — Launch the campaign

In the UI: **Campaigns** → **New Campaign**. After clicking *Launch*, watch the dashboard:

- Email sent
- Email opened (tracking pixel)
- Link clicked
- Data submitted

These are your **awareness KPIs**.

Step 6 — Convert metrics into training

	Action
< 5 %	Quarterly refresh course
5 – 15 %	Targeted micro-learning
> 15	Mandatory training + manager comms



%

The point of phishing simulations is **education**, not punishment.

Step 7 — Develop an awareness program (5.6)

A complete program needs:

- Initial onboarding training
- Recurring (annual) refresh
- **Risky behaviour** signal: clicked but did not report
- **Unexpected behaviour**: reported successfully → reward
- **Unintentional behaviour**: clicked, reported, learned

Track all three categories per user over time.

Free online tools

- **GoPhish** — https://getgophish.com
- **King Phisher** — https://github.com/rsmusllp/king-phisher
- **Evilginx (red team only)** — https://github.com/kgretzky/evilginx2
- **PhishER (free tier)** — https://www.knowbe4.com/products/phisher
- **MailHog (safe SMTP sink)** — https://github.com/mailhog/MailHog
- **CISA phishing guidance** — https://www.cisa.gov/topics/cyber-threats-and-advisories/phishing
- **Google Phishing Quiz** — https://phishingquiz.withgoogle.com

---

What you learned

- The four GoPhish primitives (profile, template, page, group).
- How to run a controlled simulation without spamming real users (MailHog sink).
- That awareness metrics drive **training**, not blame.